

Annex A

GDPR Regulatory Mapping

Companion document to *Cybersecurity for Small NGOs in Luxembourg*

Version 1.0

University of Luxembourg Project in Cybersecurity Risk Management

BAUDET Antoine

STELMES Noah

NWAOYIBO Chiamaka

DINH VO TRUC Ngan

About this annex

This annex maps every cybersecurity control in the main framework to the specific GDPR article that requires it. Each control is therefore not just a best practice but a legally grounded obligation when personal data is involved.

When an NGO implements the framework, it is also building toward GDPR compliance. This document gives you the legal reading so you can answer a funder, an auditor, or the CNPD when they ask "why are you doing this".

Who this is most useful for

Any NGO processing personal data is subject to GDPR, but this annex is most useful for NGOs that process **special-category data** under Article 9: health information, data about vulnerable individuals, data about children, biometric data, and similar categories. For these NGOs, the controls in the SD module of the framework are legal requirements, not optional add-ons.

How to read the table

The mapping table on the following pages is organised by framework section (BASICS, T1, T2, SD). For each control you will find:

Framework ref: the identifier in the framework (for example T1.1.1 or SD.5.1). You can find the full description of each control in the main guide or in the CISO Assistant framework.

GDPR article: the specific GDPR article that creates the obligation.

What it requires: a plain-language summary of why this control is required by GDPR and what good implementation looks like.

Control to GDPR article mapping

The Five Basics (BASICS)

Framework ref	GDPR article	What it requires
BASICS.1.1	Art. 32(1)(a)	Two-step login (MFA) is an "appropriate technical measure" to control access. Without it, a leaked password gives an attacker full access to personal data. GDPR requires access controls proportionate to the risk.
BASICS.1.2	Art. 32(1)(c)	Regular backups and the ability to restore them are explicitly required: "the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident".
BASICS.1.3	Art. 32(1)(b)	Keeping software up to date is part of the ongoing confidentiality and integrity of processing. Unpatched software is the most common entry point for ransomware affecting NGOs.
BASICS.1.4	Art. 32(1)(b), Art. 39(1)(b)	GDPR requires both technical AND organisational measures. Annual staff awareness is the baseline organisational measure. Article 39 specifically lists staff training as a DPO responsibility.
BASICS.1.5	Art. 33	A breach must be notified to the CNPD within 72 hours. Without a printed offline contact card, those contacts may be unreachable precisely when you need them (during an incident affecting your systems).
BASICS.1.6	Art. 32(1)(b), Art. 33	An incident response procedure is part of "ongoing confidentiality" measures, and the 72-hour breach notification clock requires a fast, predictable internal response.

Tier I controls (T1)

Framework ref	GDPR article	What it requires
T1.1.1	Art. 28, Art. 32(1)(a)	Using a nonprofit cloud workspace (Microsoft 365 or Google Workspace) gives you a vendor that signs Data Processing Agreements as required by Art. 28 and provides built-in encryption as required by Art. 32(1)(a). Running your own email or file server without those guarantees fails both articles.
T1.1.2	Art. 32(1)(a)	Enforcing 2-step verification for everyone, not just enabling the option, is the practical implementation of access control. Optional MFA is not appropriate measures.
T1.1.3	Art. 5(1)(f), Art. 32(1)(b)	Individual logins are required for accountability. Shared accounts make it impossible to trace who accessed what, which violates the integrity principle and the ability to demonstrate compliance.
T1.1.4	Art. 32(1)(a)	A password manager makes it operationally possible to use strong, unique passwords per service. Without one, staff reuse passwords (a documented common failure mode).
T1.2.2	Art. 32(1)(a)	Disk encryption is explicitly listed in Article 32(1)(a) as an example of appropriate technical measures. For laptops that may be lost or stolen, this is non-negotiable.

Framework ref	GDPR article	What it requires
T1.3.1	Art. 32(1)(a)	Email attachments containing sensitive data are easily forwarded, exfiltrated, or sent to wrong recipients. Sharing via authenticated cloud links restricts who can access what, which is an access control measure.
T1.3.3	Art. 32(1)(a), Art. 5(1)(f)	Email authentication (SPF, DKIM, DMARC) prevents your domain from being used to impersonate the NGO in phishing attacks against your staff or beneficiaries. Protects integrity of communications.
T1.4.2	Art. 32(1)(d)	Article 32(1)(d) requires "a process for regularly testing, assessing and evaluating the effectiveness of technical and organisational measures". A yearly restore test is the minimum implementation of this for backups.

Tier II controls (T2)

Framework ref	GDPR article	What it requires
T2.1.1	Art. 32(1)(a)	Conditional access policies (block unusual locations, block legacy authentication) are the modern equivalent of "access control proportionate to the risk". GDPR requires risk-proportionate measures, and these are now standard.
T2.1.2	Art. 32(1)(a), Art. 25	Separation of administrative and daily-use accounts is the principle of least privilege, a foundational element of "data protection by design" (Art. 25).
T2.1.3	Art. 32(1)(b), Art. 5(1)(f)	Quarterly access reviews ensure that people who left have lost access. Article 5(1)(f) requires confidentiality, and Article 32(1)(b) requires ongoing measures, not one-time setup.
T2.1.4	Art. 32(1)(b)	A documented 24-hour offboarding checklist ensures that departing staff cannot retain access to personal data. This is the operational implementation of ongoing confidentiality.
T2.2.1	Art. 32(1)(a)	A Mobile Device Management tool lets the NGO remotely wipe a lost or stolen device, which is a direct technical measure protecting personal data on endpoints.
T2.2.2	Art. 25, Art. 32(1)(a)	A written BYOD policy makes the rules around personal devices explicit and enforceable. Article 25 (data protection by design) requires the privacy-friendly option to be the default; a BYOD policy defines what that default is.
T2.3.1	Art. 32(1)(a), Art. 5(1)(f)	Moving email authentication to enforcement mode (rather than monitoring only) actively rejects spoofed emails. This protects the integrity of your communications with data subjects.
T2.4.2	Art. 5(1)(e)	Retention rules implement the storage limitation principle: personal data must not be kept longer than necessary. Defining the period for each type of data is the operational form of this principle.
T2.5.1	Art. 5(2), Art. 24	Article 5(2) requires the controller to be able to demonstrate compliance (accountability). Documenting the IT person's actions creates an evidence trail and avoids the "we always did it this way" problem when staff turns over.
T2.6.1	Art. 28, Art. 46	The five questions before signing with a supplier cover the Article 28 requirements (DPA) and Article 46 requirements (transfers outside the EU). Asking these questions before signing is far easier than after.

Framework ref	GDPR article	What it requires
T2.6.2	Art. 28, Art. 32(1)(d)	Annual review of key suppliers is the operational form of "regularly testing and assessing the effectiveness of measures" applied to the supply chain.

Sensitive Personal Data (SD) - GDPR add-on

Framework ref	GDPR article	What it requires
SD.0.1	Art. 9(1)	Article 9(1) prohibits the processing of special-category personal data by default. An NGO must therefore explicitly determine whether its activities fall under Article 9, because if they do, an additional legal regime applies.
SD.1.1	Art. 9(2)(a) and others	Article 9(2) lists the conditions that lift the Article 9(1) prohibition. The most common for NGOs is explicit consent (Art. 9(2)(a)). The chosen basis must be documented and the evidence retained.
SD.1.2	Art. 5(1)(c)	Data minimisation: collect only what is adequate, relevant and limited to what is necessary. The smaller the dataset, the smaller the breach impact.
SD.1.3	Art. 5(1)(e)	Storage limitation: personal data must not be kept longer than necessary for the purposes for which it was collected. Retention periods must be defined.
SD.2.1	Art. 37, Art. 38, Art. 39	A DPO is required when an organisation's core activities consist of large-scale processing of special-category data. The DPO must have independence, dedicated time, and direct access to leadership. The CNPD must be notified of the DPO contact details.
SD.3.1	Art. 30	Record of processing activities is mandatory regardless of NGO size when special-category data is involved (the under-250-staff exemption in Art. 30(5) does not apply). It must document what data, why, who, retention, recipients.
SD.3.2	Art. 35	A DPIA is required before processing that is likely to result in a high risk to data subjects, which is automatic for large-scale special-category processing. The DPIA documents the risk and the mitigations.
SD.4.1	Art. 12 to Art. 22	Data subjects have rights to access, rectification, erasure, restriction, portability, and to object. The NGO has one month to respond. A documented procedure ensures these deadlines are met.
SD.5.1	Art. 33	A personal data breach must be notified to the CNPD within 72 hours of awareness, unless the breach is unlikely to risk individuals. The 72-hour clock makes a documented procedure non-negotiable.
SD.5.2	Art. 34	When the breach is likely to result in a high risk to individuals (e.g. sensitive health data leaked), the affected individuals must be notified directly without undue delay.
SD.6.1	Art. 28	Every third-party processor handling personal data on behalf of the NGO must have a signed Data Processing Agreement. This includes the cloud workspace, mailing services, accounting software, payment processors, etc.

Framework ref	GDPR article	What it requires
SD.6.2	Art. 44 to Art. 49	Personal data transfers outside the EU/EEA require appropriate safeguards (Standard Contractual Clauses, adequacy decisions, or another Art. 46 mechanism). This applies to many US-based subprocessors.
SD.7.1	Art. 32(1)(d)	Periodic external review implements the "regular testing, assessing and evaluating" requirement of Article 32(1)(d). For sensitive data, an outside perspective is the most reliable form of this evaluation.

GDPR articles referenced in this annex

A short reference for each article cited in the mapping table. For the full text, consult the official GDPR (Regulation 2016/679) or the CNPD website.

Art. 5(1)(c) - Data minimisation

Personal data must be adequate, relevant and limited to what is necessary in relation to the purposes for which it is processed.

Art. 5(1)(e) - Storage limitation

Personal data must be kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the data are processed.

Art. 5(1)(f) - Integrity and confidentiality

Personal data must be processed in a manner that ensures appropriate security, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage.

Art. 5(2) - Accountability

The controller is responsible for, and must be able to demonstrate compliance with, the principles set out in Article 5(1).

Art. 9(1) - Processing of special categories of personal data

Processing of personal data revealing racial or ethnic origin, political opinions, religious beliefs, trade-union membership, genetic data, biometric data, health data, or data concerning a natural person's sex life or sexual orientation is prohibited.

Art. 9(2) - Exceptions to the prohibition

The prohibition in Article 9(1) does not apply when one of the listed conditions is met, most notably (a) the data subject has given explicit consent.

Art. 12 to Art. 22 - Rights of the data subject

These articles establish the rights of data subjects: information, access, rectification, erasure, restriction, portability, objection, and rights related to automated decision-making.

Art. 24 - Responsibility of the controller

The controller must implement appropriate technical and organisational measures to ensure and demonstrate that processing is performed in accordance with the GDPR.

Art. 25 - Data protection by design and by default

The controller must implement appropriate technical and organisational measures designed to implement data-protection principles in an effective manner. The privacy-friendly option must be the default.

Art. 28 - Processor obligations

When processing is carried out on behalf of a controller, the controller must use only processors providing sufficient guarantees, and the relationship must be governed by a binding contract (Data Processing Agreement).

Art. 30 - Records of processing activities

Controllers and processors must maintain a record of processing activities under their responsibility. The exemption for organisations under 250 employees in Article 30(5) does not apply to processing of special-category data.

Art. 32 - Security of processing

Controllers and processors must implement appropriate technical and organisational measures including, as appropriate: (a) pseudonymisation and encryption, (b) ongoing confidentiality, integrity, availability and resilience, (c) ability to restore availability and access in a timely manner, and (d) regular testing and assessment of the effectiveness of measures.

Art. 33 - Notification of a personal data breach to the supervisory authority

In the case of a personal data breach, the controller must notify the supervisory authority (CNPD in Luxembourg) without undue delay and, where feasible, not later than 72 hours after becoming aware of the breach, unless the breach is unlikely to result in a risk to individuals.

Art. 34 - Communication of a personal data breach to the data subject

When a personal data breach is likely to result in a high risk to the rights and freedoms of natural persons, the controller must communicate the breach to the data subject without undue delay.

Art. 35 - Data protection impact assessment

Where processing is likely to result in a high risk to the rights and freedoms of natural persons, the controller must, prior to the processing, carry out an assessment of the impact of the envisaged processing operations.

Art. 37 to Art. 39 - Data Protection Officer

These articles establish the conditions under which a DPO must be designated, the position of the DPO within the organisation, and the tasks of the DPO.

Art. 44 to Art. 49 - Transfers of personal data to third countries

These articles set the general principle that transfers of personal data outside the EU/EEA may only take place where appropriate safeguards are in place, including adequacy decisions (Art. 45), appropriate safeguards (Art. 46), or specific derogations.

Disclaimer

This annex is a working framework, not legal advice. It is intended to help small NGOs in Luxembourg understand how the cybersecurity controls in the main guide relate to GDPR obligations, in plain language.

For binding interpretation of GDPR, of the Luxembourg ASBL law, the ASFT law, NIS2, or sector-specific requirements, consult a lawyer or the relevant Luxembourg authority. GDPR enforcement evolves: review this annex annually alongside the main guide.

For questions about specific provisions of GDPR, the CNPD (Commission nationale pour la protection des données) publishes practical guidance on its website and may be contacted directly. For questions specific to small NGOs, peer networks like the Cercle des associations de patients can be a useful starting point.

Companion document to "Cybersecurity for Small NGOs in Luxembourg", University of Luxembourg Project in Cybersecurity Risk Management.